

This generic sample form is intended for use only as a model from which to begin developing your own customized document. It may include information that does not apply to your institution and it may not include all of the information your own policy statement might require to ensure that you meet your regulatory and legal obligations. For legal advice or other expert assistance in adapting it to your own situation, the services of a competent professional should be sought. This form is provided for use only by financial institutions that have current licensing agreements with BVS, Inc.

[NAME OF INSTITUTION]

Third-Party Service Provider Management Policy and Procedures

Policy Statement

Third-party service providers such as vendors, brokers, dealers and agents can offer a financial institution a variety of legitimate and safe opportunities to enhance its product offerings, improve earnings, diversify assets and revenues, or reduce costs. However, the Board of Directors of [Name of institution] understands the risks arising from such arrangements with third parties. Therefore, the Board directs management to exercise appropriate due diligence prior to entering a third-party arrangement and to establish procedures for effective oversight and control afterwards.

The Board appoints [insert the name and/or title of the appropriate officer] as the officer responsible for vendor management. The Board further directs the internal auditor to conduct a review of the institution's vendor management at least once per year and report the results of the audit, including management responses, to the Board or an appropriate committee.

All third-party arrangements will be assessed in the following areas in a manner commensurate with their size, complexity and risk profile:

- Risk Assessment and Planning
- Due Diligence
- Risk Measurement, Monitoring and Control

This assessment must be documented in writing. For all significant projects, the institution will send out requests for proposals (RFPs) to at least [three] vendors. Depending on the size and complexity of other outsourcing projects, management may or may not, at its discretion, send RFPs for other outsourcing projects. Management will obtain the Board's approval prior to proceeding without sending RFPs.

All third-party service provider arrangements [in excess of _____] must receive the prior approval of the Board of Directors.

Risk Assessment and Planning Considerations

A risk assessment will be conducted prior to sending RFPs (or prior to soliciting bids from third parties if no RFP is used). Risk assessments for less complex third-party arrangements may be part of a broader risk management program or documented in Board minutes. Management will consider the following elements in evaluating the adequacy of the institution's risk assessment and due diligence over third-party relationships:

Planning and Initial Risk Assessment

Before entering into a third-party relationship, management will determine whether the relationship complements the institution's overall mission and philosophy and document how the relationship will relate to the institution's strategic plan, considering long-term goals, objectives and resource-allocation requirements.

Management should design action plans to achieve short-term and long-term objectives in support of strategic planning for new third-party arrangements. All planning should contain measurable, achievable goals and clearly defined levels of authority and responsibility.

Management should weigh the risks and benefits of outsourcing business functions with the risks and benefits of maintaining those functions in-house. In addition, management should assess what internal changes, if any, will be required to safely and soundly participate.

The initial risk assessments for a third-party relationship must consider all seven risk areas:

- Credit
- Interest Rate
- Liquidity
- Transaction
- Compliance
- Strategic
- Reputation

In addition, the risk assessment must address the following issues:

- **Expectations for Outsourced Functions:** Management should clearly define the nature and scope of the institution's needs. Which needs will the third party meet? Will the third party be responsible for desired results? To what extent?
- **Staff Expertise:** Is the institution's staff qualified to manage and monitor the third-party relationship? How much reliance on the third party will be necessary?
- **Criticality:** How important is the activity to be outsourced? Is the activity mission-critical? What other alternatives exist?
- **Risk-Reward or Cost-Benefit Relationship:** Does the potential benefit of the arrangement outweigh the potential risks or costs? Will this change over time?
- **Insurance:** Will the arrangement create additional liabilities? Is the institution's insurance coverage sufficient to cover the potentially increased liabilities? Will the third party carry "key man" insurance or other insurance to protect the institution?
- **Impact on Customers:** How will management gauge the positive or negative impacts of

the arrangement on customers? How will they manage customer expectations?

- **Exit Strategy:** Is there a reasonable way out of the relationship if it becomes necessary to change course in the future? Can another party provide any services management deems critical?

Financial Projections

In evaluating the cost-benefit or risk-reward of a third-party relationship, management should develop financial projections outlining the range of expected and possible financial outcomes.

Due Diligence for Third-Party Relationships

When considering third-party relationships, proper due diligence includes developing a demonstrated understanding of a third party's organization, business model, financial health and program risks. Therefore, the risk assessment must include the following due diligence:

- **Background Check:** Management must conduct a background check of each prospective third-party provider both in terms of the third party's general business reputation and its ability to provide the services requested. The background check should include consideration of the third party's experience providing the proposed service or program, including verification of the expertise the vendor has obtained to provide the service. Management should request referrals from the prospective third party's clients to determine their satisfaction and experience with the arrangement. Additionally, management should ensure that third parties or their agents have any required licenses or certifications and that they remain current for the duration of the arrangement.
- **Business Model:** When evaluating a prospective third-party arrangement, management should consider the longevity and adaptability of third-party business models.
- **Cash Flows:** Management must understand how cash flows (both incoming and outgoing) move between the customer, the third party and the institution. Management should also be able to independently verify the source of these cash flows and match them to related individual accounts.
- **Policies/Procedures:** Depending on the type of third party being reviewed, management should request and review the vendor's internal policies, procedures, internal controls and training materials for consumer protection laws to ensure that the service provider has conducted training and has appropriate controls in place for employees or agents that have consumer contact or compliance responsibility.

The due diligence necessary to ensure that the risks undertaken in a third-party relationship are acceptable varies in relation to the third party's risk profile, and the institution's safety and soundness requirements. Less complex risk profiles and third-party arrangements typically require less analysis and documentation.

Financial and Operational Control Review

If the third party will perform mission-critical functions or perform other functions that pose a high financial or other risk if the contract is not fulfilled, management should carefully review the financial condition of the third party and its closely related affiliates. The financial statements of a third party and its closely related affiliates should demonstrate an ability to fulfill the

contractual commitments proposed. If available, management can use copies of SSAE 16 reports prepared by an independent auditor, audit results or regulatory reports to evaluate the adequacy of the proposed vendor's internal controls. If these items are not available, management should consider whether to require an independent review of the proposed vendor's internal controls. Generally, contracts establish requirements for periodic audits or access to third-party records.

Consumer Protection Laws

Management should take steps to establish ongoing monitoring of third-party providers of consumer products in order to ensure compliance with all consumer protection laws, including, if appropriate, on-site compliance reviews/audits. Management may also consider requesting copies of the vendor's internal review process for compliance with consumer protection laws and regulations.

Prompt action should be taken if management suspects any potential violation of a consumer protection law or the vendor's possible unfair, deceptive, or abusive act or practice.

Contract Issues and Legal Review

Management should take measures to ensure careful review and understanding of the contract and legal issues relevant to third-party arrangements. In particular, it must seek qualified external legal counsel as necessary to review prospective third-party arrangements and contracts.

All third-party service provider agreements must be in writing. Typically, at a minimum, third-party contracts should address the following:

- Scope of arrangement, services offered and activities authorized
- Responsibilities of all parties (including subcontractor oversight)
- Service level agreements addressing performance standards and measures
- Performance reports and frequency of reporting
- Penalties for lack of performance
- Ownership, control, maintenance and access to financial and operating records
- Ownership of servicing rights
- Audit rights and requirements (including responsibility for payment)
- Data security and customer confidentiality (including testing and audit)
- Business resumption or contingency planning
- Insurance
- Customer complaints and customer service
- Compliance with regulatory requirements (e.g., UDAAP, GLBA, Privacy, BSA and all consumer protection laws and regulations that may apply)
- Dispute resolution
- Default, termination and escape clauses

Management must exercise its right to negotiate contract terms with third parties for mutually beneficial contracts. In particular, significant buyout or termination penalties, early termination, escape clause and default terms must be carefully reviewed. Management should ensure that any

contract terms agreed to would not adversely affect the institution's safety and soundness, regardless of contract performance.

Accounting Considerations

Management must ensure that it has adequate accounting infrastructures to appropriately track, identify and classify transactions in accordance with Generally Accepted Accounting Principles (GAAP) and seek a certified public accountant's guidance as necessary to ensure proper accounting treatment.

Risk Measurement, Monitoring and Control of Third-Party Relationships

Management must, as part of all third-party service provider arrangements, establish ongoing expectations and limitations, compare program performance to expectations and ensure all parties to the arrangement are fulfilling their responsibilities.

Policies and Procedures

Management should develop detailed policy guidance sufficient to outline expectations and limit risks originating from third-party arrangements. Policies and procedures should outline staff responsibilities and authorities for third-party processes and program oversight. This guidance should define the content and frequency of reporting to bank management and the Board of Directors. If applicable, management should also establish program limitations to control the pace of program growth and allow time to develop experience with the program.

Risk Measurement and Monitoring

Management must be able to measure the risks of third-party programs as well as the performance of third parties in terms of profitability, benefit and service delivery. Management must also make sure it has the knowledge, skills and abilities available that are necessary to monitor and control third-party arrangements. To the extent that management relies on a third party to provide this type of measurement information, clear controls should be contractually established and subject to periodic independent testing to ensure the accuracy of the information.

Control Systems and Reporting

After management has conducted internal risk assessments and due diligence over prospective third parties, it must implement appropriate ongoing controls over third-party arrangements to mitigate risks. Responsible staff should measure the performance of third-party programs in relation to bank policy guidance, contractual commitments and service levels. Management and the Board of Directors should receive periodic reports on the performance of all material third-party programs.

The Board of Directors approved and adopted this policy on _____.